مقيد

شركة القيروان لنظم المعلومات

سياسة حماية البيانات

سياسة تنظيمية · برنامج الالتزام بالضوابط الأساسية للأمن السيبراني

رقم الوثيقة	**QIS-POL-001**
الإصدار	٠٫٤ (مسودة)
التاريخ	١١ نوفمبر ٢٠٢٦م
التصنيف	مقيد
إشارة المشاركة	برتقالي · TLP:AMBER

إعداد نايف السالم، قائد الحوكمة والمخاطر والالتزام

دراسة حالة افتراضية. شركة القيروان لنظم المعلومات (QIS) وموظفوها وعملاؤها جهات وشخصيات افتراضية أُعدّت لملف أعمال مهني، وأي تشابه مع جهة حقيقية غير مقصود. أما الجهات التنظيمية والأطر المذكورة فهي حقيقية. لغة الوثيقة. تصدر هذه الوثيقة باللغتين العربية والإنجليزية، وفي حال وجود تعارض بين النصين يُعتمد النص العربي.

معلومات السياسة

اسم السياسة	سياسة حماية البيانات
رمز السياسة	QIS-POL-001
مالك السياسة	قائد الحوكمة والمخاطر والالتزام — نايف السالم
مُعِدّ السياسة	نايف السالم — قائد الحوكمة والمخاطر والالتزام
تاريخ بناء السياسة	٥ نوفمبر ٢٠٢٦م
إصدار السياسة	٠٫٤ (مسودة)
الإجراءات التنفيذية	QIS-PRC-001 إجراءات حماية البيانات

إشارة المشاركة (Traffic Light Protocol)

صُنّفت هذه السياسة وفق بروتوكول الإشارة الضوئية (TLP) المعتمد في وثائق الهيئة الوطنية للأمن السيبراني عند المستوى **برتقالي (TLP:AMBER)**، ولا يجوز تداولها خارج هذا النطاق دون موافقة مالك الوثيقة.

● **أحمر** TLP:RED	شخصي وسري للمستلم فقط: لا يجوز للمستلم مشاركتها مع أي فرد من داخل الجهة أو خارجها خارج النطاق المحدد للاستلام.
● **برتقالي** TLP:AMBER	**مشاركة محدودة: يجوز للمستلم مشاركتها داخل جهته مع الأشخاص المعنيين فقط، ومن يتطلب الأمر منهم اتخاذ إجراء بشأنها. — المستوى المعتمد لهذه الوثيقة**
● **أخضر** TLP:GREEN	مشاركة في نفس المجتمع: يجوز مشاركتها مع الجهة نفسها أو جهة ذات علاقة أو في القطاع نفسه، دون تبادلها أو نشرها عبر القنوات العامة.
● **أبيض** TLP:WHITE	غير محدود.

سجل التعديلات

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠٫١	٥ نوفمبر ٢٠٢٦م	نايف السالم	المسودة الأولى: أحد عشر بنداً مع مؤشرات الأداء والمخاطر.

النسخة	التاريخ	عُدّل بواسطة	أسباب التعديل
٠,٢	١٠ نوفمبر ٢٠٢٦م	نايف السالم	إعادة البناء وفق القالب المعتمد لسياسات الشركة، وربط البنود بالضوابط الأساسية للأمن السيبراني وضوابط الأمن السيبراني للبيانات، وإضافة المواءمة مع نظام حماية البيانات الشخصية، ونقل الخطوات التنفيذية إلى QIS-PRC-001، واعتماد الهوية البصرية الجديدة.
٠,٣	١٠ نوفمبر ٢٠٢٦م	نايف السالم	مطابقة القسم ٨ مع النص الرسمي للضوابط الأساسية للأمن السيبراني (ECC-2:2024): تقليص المكون الفرعي ٢-٧ إلى ثلاثة ضوابط، وإضافة المعايير الوطنية للتشفير إلى ٢-٨-٣، وإضافة خدمات الإسناد للأمن السيبراني إلى ٤-١، وحذف متطلب الاستضافة داخل المملكة من نص ٤-٢-٣ وإبقائه متطلباً للشركة مستنداً إلى مرجعه الحالي.
٠,٤	١١ نوفمبر ٢٠٢٦م	نايف السالم	نقل نصوص الأهداف والضوابط في القسم ٨ حرفياً من النص العربي الرسمي للضوابط الأساسية للأمن السيبراني (ECC-2:2024) مع ضوابطها الفرعية، ومنها إضافة المعالجة إلى تشفير البيانات في ٢-٨-٣-٣. واعتماد الأرقام الهندية وترتيب أرقام الضوابط كما في وثائق الهيئة.

اعتماد الوثيقة

الدور	المسمى الوظيفي	الاسم	التاريخ	التوقيع
المالك	قائد الحوكمة والمخاطر والالتزام	نايف السالم	—	—
المُراجِع	الرئيس التنفيذي للتقنية	ريم العتيبي	—	—
المُراجِع	رئيس تقديم الخدمات	سلطان الدوسري	—	—
المُراجِع	الرئيس التنفيذي للمالية (العقود والموارد البشرية)	ماجد القحطاني	—	—
المُصرِّح	رئيس اللجنة الإشرافية للأمن السيبراني	فيصل الحربي	—	—
المعتمِد	الرئيس التنفيذي	فيصل الحربي	—	—

جدول المراجعة

معدل المراجعة	تاريخ آخر مراجعة	تاريخ المراجعة القادمة
سنوياً، أو عند تغيّر الأنظمة واللوائح أو خدمات الشركة أو بعد حادثة تمس البيانات	—	نوفمبر ٢٠٢٧م

تصنيف السياسة

سري للغاية	تُصنّف السياسة «سري للغاية» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم لا يمكن تداركه أو إصلاحه.
سري	تُصنّف السياسة «سري» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر جسيم، وينطبق على المعلومات الحساسة التي تحدد طريقة عمل الشركة.
مقيد	**تُصنّف السياسة «مقيد» إذا كان الوصول غير المصرح به إليها أو الإفصاح عنها أو عن محتواها يؤدي إلى ضرر محدود، وينطبق على المعلومات التي لم تُعتمد للتداول العام خارج الشركة.**
عام	تُصنّف السياسة «عام» عندما لا يترتب على الوصول غير المصرح به إليها أو الإفصاح عن محتواها أي أثر على الشركة، وينطبق على الوثائق المعتمدة للنشر العام.

سرية السياسة

تعد هذه السياسة إحدى وثائق شركة القيروان لنظم المعلومات المصنفة «مقيد»، ويقتصر تداولها على منسوبي الشركة والجهات الحكومية المتعاقدة معها التي تحتاج إلى الاطلاع عليها، ولا يحق نشرها أو تعديلها أو نشر جزء منها لغير المصرح لهم إلا بموافقة كتابية مسبقة من مالك السياسة.

جدول المحتويات

١. المصطلحات والتعاريف

٢. المقدمة

٣. الغرض من السياسة

٤. نطاق التطبيق

٥. الالتزام بالسياسة

٦. الأدوار والمسؤوليات

٦٫١ مصفوفة المسؤوليات (RACI) · ٦٫٢ دور الشركة ومسؤول حماية البيانات الشخصية

٧. المبادئ

٨. بنود السياسة — الضوابط الأساسية للأمن السيبراني وضوابط الأمن السيبراني للبيانات

٩. المواءمة مع نظام حماية البيانات الشخصية

١٠. مؤشرات الأداء الرئيسية (KPIs)

١١. مؤشرات أداء المخاطر (KRIs)

١٢. عواقب عدم الامتثال

١٣. آلية التواصل

١٤. المراجعة وتحديث السياسة

١٥. المراجع

مقيد

١. المصطلحات والتعاريف

المصطلح	التعريف
البيانات	مجموعة من الحقائق في صورتها الأولية أو غير المنظمة، مثل الأرقام والحروف والصور، بأي شكل كانت: إلكترونية أو ورقية.
بيانات العملاء	أي بيانات تعود للعملاء من (أ) إلى (و) وتعالجها الشركة أو تستضيفها أو تصل إليها بموجب عقد، أياً كان تصنيفها.
البيانات الشخصية	كل بيان يمكن من خلاله معرفة الفرد أو تمييزه بصفة مباشرة أو غير مباشرة، كبيانات المواطنين في بوابة العميل (أ) وسجلات الطلاب لدى العميل (ج).
جهة التحكم	الجهة التي تحدد الغرض من معالجة البيانات الشخصية وكيفيتها. وهي العميل الحكومي في البيانات التي تعالجها الشركة نيابة عنه.
جهة المعالجة	الجهة التي تعالج البيانات الشخصية لمصلحة جهة التحكم ونيابة عنها. وهي الشركة في الخدمات التي تقدمها لعملائها.
مالك البيانات	الشخص أو الإدارة المسؤولة عن تحديد تصنيف البيانات واعتماد الوصول إليها ومشاركتها. وهو لدى بيانات العملاء العميل نفسه.
مستويات التصنيف	سري للغاية، وسري، ومقيد، وعام، وفق مستويات تصنيف البيانات الوطنية.
الطرف الخارجي	أي جهة تقدم للشركة خدمات أو منتجات وتصل إلى بياناتها أو بيانات عملائها، ومنها مزوّد الخدمات السحابية والمتعاقدون.
المسح الأمني (Screening / Vetting)	التحقق من خلفية الشخص وموثوقيته قبل منحه صلاحية الوصول إلى البيانات.
تعتيم البيانات (Data Masking)	استبدال قيم البيانات الحساسة بقيم غير حقيقية تحافظ على شكلها، لاستخدامها في التطوير والاختبار أو عند المشاركة.
مزج البيانات (Data Scrambling)	إعادة ترتيب قيم البيانات أو خلطها بحيث يتعذر ربطها بأصحابها.
القاعة المغلقة	مكان عمل مخصص ومحكوم الدخول والخروج لمعالجة بيانات المشاريع ذات الحساسية العالية.
تسرب البيانات	أي وصول أو كشف أو تعديل أو فقدان أو إتلاف غير مصرح به للبيانات، فعلياً كان أو مشتبهاً به.
الإتلاف الآمن	إزالة البيانات من وسائط التخزين بطريقة لا تسمح باستعادتها، مع توثيق ذلك بشهادة إتلاف.
منع تسرب البيانات (DLP)	تقنية تهدف إلى منع خروج البيانات الحساسة من الشركة عبر قنوات غير مصرح بها.

المصطلح	التعريف
مؤشر الأداء الرئيسي (KPI)	مقياس يُستخدم لتقييم مدى تحقيق الأهداف المحددة وقياس أداء العمليات والضوابط.
مؤشر المخاطر الرئيسي (KRI)	مقياس يُستخدم لمراقبة مستوى المخاطر عبر الإشارة المبكرة إلى اقترابها من حدود الرغبة في المخاطر.
السياسة	وثيقة رسمية معتمدة تتضمن المبادئ والقواعد التي تنظم عمل الشركة، وتحدد الإطار العام للقرارات والالتزام.
الإجراء	وثيقة تنفيذية منبثقة من السياسة تحدد خطوات العمل ومالكها ومخرجاتها ومددها والسجلات الواجب الاحتفاظ بها.

٢. المقدمة

تقدم شركة القيروان لنظم المعلومات خدمات تقنية مُدارة واستضافة وتطوير برمجيات لست جهات حكومية، وتعالج نيابة عنها بيانات مصنفة وبيانات شخصية لمواطنين وطلاب، ويعمل معها متعاقدون ومزوّد خدمات سحابية. ولأن البيانات هي جوهر ما يأتمنها عليه العملاء، فإن أي تسرب لها يمس ثقتهم وسمعة الشركة ووفاءها بالتزاماتها النظامية والتعاقدية.

٣. الغرض من السياسة

تهدف هذه السياسة إلى حماية البيانات التي تملكها الشركة أو تعالجها نيابة عن عملائها طوال دورة حياتها، من الجمع والمعالجة والتخزين والنقل والمشاركة إلى الحفظ والإتلاف، بما يحقق سريتها وسلامتها وتوافرها، ويضمن حماية البيانات عند تعامل الأطراف الخارجية معها.

وقد بُنيت بنود السياسة على الضوابط الأساسية للأمن السيبراني (ECC-2:2024) وضوابط الأمن السيبراني للبيانات (DCC-1:2022) الصادرة عن الهيئة الوطنية للأمن السيبراني، ونظام حماية البيانات الشخصية ولائحته التنفيذية، والالتزامات التعاقدية تجاه العملاء.

٤. نطاق التطبيق

- جميع البيانات التي تملكها الشركة أو تعالجها للعملاء من (أ) إلى (و)، بأي شكل كانت: إلكترونية أو ورقية.
- جميع الأنظمة والأصول الواردة في نطاق البرنامج (QIS-PRF-001)، ومنها الأنظمة المستضافة وبوابة المواطنين.
- جميع الموظفين والمتعاقدين في الرياض وجدة.

- جميع الأطراف الخارجية التي تصل إلى بيانات الشركة أو بيانات عملائها، ومنها مزوّد الخدمات السحابية.
- جميع مراحل دورة حياة البيانات: الجمع، والمعالجة، والتخزين، والنقل، والمشاركة، والحفظ، والإتلاف.

٥. الالتزام بالسياسة

يجب على قائد الحوكمة والمخاطر والالتزام التأكد من التزام الشركة بهذه السياسة، وتلتزم جميع الإدارات المعنية بتطبيق ما ورد فيها. وتُنفَّذ بنود السياسة وفق الإجراءات التفصيلية الواردة في QIS-PRC-001، وعند التعارض تُقدَّم أحكام هذه السياسة، ثم الأنظمة والتشريعات ذات العلاقة، ثم الالتزامات التعاقدية الأشد.

٦. الأدوار والمسؤوليات

الدور	المسؤوليات
الرئيس التنفيذي	يعتمد السياسة، ويوفر الموارد اللازمة لتطبيقها، ويعتمد الاستثناءات، ويوقّع العقود التي تتضمن متطلبات حماية البيانات.
اللجنة الإشرافية للأمن السيبراني	تصادق على السياسة، وتتابع مؤشراتها ربع سنوياً، وتصعّد المؤشرات الحمراء، وتعتمد المشاريع ذات الحساسية العالية.
قائد الحوكمة والمخاطر والالتزام (مسؤول حماية البيانات الشخصية)	يملك السياسة ويحدّثها، ويتابع الالتزام بها، ويراجع متطلبات الأمن السيبراني في العقود، وينسق مع جهات التحكم، ويرفع تقارير المؤشرات.
العمليات والهندسة الأمنية	تطبق ضوابط منع تسرب البيانات ومراقبتها، وتتحقق من المسح الأمني ونتائجه، وتقود الاستجابة لحوادث تسرب البيانات.
الرئيس التنفيذي للتقنية	يطبق الضوابط التقنية: التشفير، والتحكم في الوصول، وفصل البيئات، والإتلاف الآمن، وإدارة مزوّد الخدمات السحابية.
رئيس تقديم الخدمات	يطبق السياسة في الخدمات المُدارة، وينقل تعليمات العملاء الموثقة بشأن بياناتهم، ويبلغهم بالحوادث.
الرئيس التنفيذي للمالية	يضمّن بنود حماية البيانات والسرية في العقود، ويتابع المسح الأمني للمتعاقدين مع الموارد البشرية، وإنهاء الوصول عند المغادرة.
المراجع المستقل	يتحقق سنوياً من تطبيق السياسة ومدى فاعلية ضوابطها.
جميع الموظفين والمتعاقدين	يلتزمون بالسياسة، ويتعاملون مع البيانات وفق تصنيفها، ويبلغون فوراً عن أي تسرب فعلي أو مشتبه به.

٦,١ مصفوفة المسؤوليات (RACI)

التنفيذي: الرئيس التنفيذي · اللجنة: اللجنة الإشرافية للأمن السيبراني · الحوكمة: الحوكمة والمخاطر والالتزام · الأمن: العمليات والهندسة الأمنية · التقنية: الرئيس التنفيذي للتقنية · الخدمات: تقديم الخدمات · المالية: الرئيس التنفيذي للمالية

R — المنفذ (Responsible) · A — المسؤول النهائي (Accountable) · C — يُستشار (Consulted) · I — يُبلَّغ (Informed)

النشاط	التنفيذي	اللجنة	الحوكمة	الأمن	التقنية	الخدمات	المالية
اعتماد السياسة وتحديثاتها	A	C	R	C	C	C	C
تصنيف البيانات وتوثيقه	I	I	A	C	R	R	I
متطلبات الأمن السيبراني في العقود	A	I	R	C	C	C	R
المسح الأمني للأطراف الخارجية	I	I	C	A	I	I	R
منح الوصول إلى البيانات ومشاركتها	I	I	C	A	R	C	I
التشفير وإدارة المفاتيح	I	I	C	C	A/R	I	I
الاستجابة لتسرب البيانات والإبلاغ	I	I	R	A/R	R	R	I
الإتلاف الآمن وإعادة البيانات	I	I	C	C	A/R	R	I
قياس المؤشرات (KPIs / KRIs)	I	C	A/R	C	C	C	I

٦,٢ دور الشركة ومسؤول حماية البيانات الشخصية

بند مضاف — شركة القيروان لنظم المعلومات

لا يرد هذا البند بهذه الصيغة في الوثائق المرجعية، وقد أُضيف لأن الشركة جهة معالجة لعملائها وجهة تحكم في بياناتها الداخلية، ولا تملك بعد وظيفة مستقلة لحماية البيانات.

QIS-ORG-1	تعمل الشركة جهةَ معالجة في بيانات العملاء، فلا تعالجها إلا وفق العقد والتعليمات الموثقة من جهة التحكم، وتعمل جهةَ تحكم في بيانات موظفيها ومتعاقديها.
QIS-ORG-2	يتولى قائد الحوكمة والمخاطر والالتزام مهام مسؤول حماية البيانات الشخصية إلى حين تعيين مسؤول مستقل، ويُفصل بين هذا الدور وبين تشغيل الأنظمة التي تعالج البيانات.
QIS-ORG-3	تُحدَّث مصفوفة المسؤوليات عند تعيين رئيس إدارة الأمن السيبراني أو مسؤول مستقل لحماية البيانات، ويُصدر تحديث لهذه السياسة يوثق ذلك.

٧. المبادئ

٧,١ المعالجة وفق التعليمات

تُعالج بيانات العملاء للغرض المحدد في العقد ووفق تعليمات جهة التحكم الموثقة فقط، ولا تُستخدم لأي غرض آخر.

٧,٢ الحد الأدنى

تُجمع البيانات وتُتاح وتُشارك بالقدر اللازم لتحقيق الغرض فقط، وتُخفَّض إلى أقل مستوى تصنيف يحقق الهدف قبل مشاركتها.

٧,٣ السيادة على البيانات

تُخزَّن بيانات العملاء وتُعالج داخل المملكة العربية السعودية، ولا تُنقل خارجها إلا وفق ما يجيزه النظام وبموافقة جهة التحكم.

٧,٤ الحماية طوال دورة الحياة

تُطبَّق الضوابط بحسب تصنيف البيانات في كل مرحلة، من الجمع إلى الإتلاف الآمن.

٧,٥ المساءلة

لكل مجموعة بيانات مالك محدد، وكل وصول إليها أو مشاركة لها موثقة وقابلة للتتبع.

٨. بنود السياسة — الضوابط الأساسية للأمن السيبراني وضوابط الأمن السيبراني للبيانات

تلتزم الشركة بالضوابط الأساسية للأمن السيبراني (ECC-2:2024) في المكونات الفرعية التالية، وتطبق إلى جانبها ما ينطبق من ضوابط الأمن السيبراني للبيانات (DCC-1:2022) بصفتها جهة تعالج بيانات حكومية. وتُعرض تحت كل مكون فرعي ضوابطه، ثم المتطلبات التنفيذية الإضافية التي تضعها الشركة.

٢ تعزيز الأمن السيبراني (Cybersecurity Defense)

ألغى الإصدار ٢٠٢٤ من الضوابط البنود الفرعية لملكية البيانات وتصنيفها وترميزها وخصوصيتها، وأحال خصوصية البيانات إلى مكتب إدارة البيانات الوطنية. وتُبقي الشركة متطلباتها في هذه الجوانب ضمن متطلباتها التنفيذية أدناه.

٧-٢ حماية البيانات والمعلومات (Data and Information Protection)

الهدف: ضمان حماية السرية وسلامة بيانات ومعلومات الجهة ودقتها وتوافرها، وذلك وفقاً للسياسات والإجراءات التنظيمية للجهة، والمتطلبات التشريعية والتنظيمية ذات العلاقة.

الرقم	الضوابط
١-٧-٢	يجب تحديد وتوثيق واعتماد متطلبات الأمن السيبراني لحماية بيانات ومعلومات الجهة، والتعامل معها وفقاً للمتطلبات التشريعية والتنظيمية ذات العلاقة.
٢-٧-٢	يجب تطبيق متطلبات الأمن السيبراني لحماية بيانات ومعلومات الجهة، حسب مستوى تصنيفها.
٣-٧-٢	يجب مراجعة تطبيق متطلبات الأمن السيبراني لحماية بيانات ومعلومات الجهة دورياً.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-7-1	تُصنَّف بيانات العملاء وفق تصنيف العميل نفسه، وتُصنَّف بيانات الشركة وفق مستويات التصنيف الوطنية، ولا يُشغَّل أي نظام يحتفظ ببيانات «مقيد» أو أعلى قبل توثيق تصنيفها ومالكها.
QIS-2-7-2	تُطبَّق قواعد التخزين والنقل والمشاركة والإتلاف بحسب مستوى التصنيف وفق الجدول (٨-١).
QIS-2-7-3	يُحتفظ بسجل لأنشطة معالجة البيانات الشخصية لكل عميل، يتضمن الغرض والفئات ومدة الحفظ والأطراف المطلعة.
QIS-2-7-4	يُمنع استخدام بيانات شخصية حقيقية في بيئات التطوير والاختبار، وتُستخدم بيانات مُعتَّمة أو مُصطنعة، إلا بموافقة كتابية من جهة التحكم وقائد الحوكمة والمخاطر والالتزام.
QIS-2-7-5	تُطبَّق ضوابط منع تسرب البيانات على البريد الإلكتروني وخدمات التخزين السحابي والأجهزة الطرفية، وتُراجع تنبيهاتها يومياً.
QIS-2-7-6	تُحفظ البيانات للمدة المحددة في العقد أو النظام أيهما أطول، ثم تُتلف إتلافاً آمناً موثقاً بشهادة إتلاف للبيانات «مقيد» وما فوقها.

الجدول (٨-١): قواعد التعامل مع البيانات بحسب التصنيف

المستوى	التخزين	النقل	المشاركة	الإتلاف
سري للغاية وسري	داخل المملكة، مشفّر، في أنظمة معزولة بإذن العميل	مشفّر، وبموافقة العميل الكتابية	ممنوعة إلا بموافقة كتابية من جهة التحكم	إتلاف آمن مع شهادة إتلاف
مقيد	داخل المملكة، مشفّر أثناء التخزين	مشفّر دائماً	لمن يحتاجها لأداء عمله وبموجب عقد	إتلاف آمن موثق
عام	دون قيود خاصة	دون قيود خاصة	مسموحة	حذف اعتيادي

٨-٢ التشفير (Cryptography)

الهدف: ضمان الاستخدام السليم والفعال للتشفير لحماية الأصول المعلوماتية الإلكترونية للجهة، وذلك وفقاً للمعايير الوطنية للتشفير الصادرة من الهيئة، وللسياسات والإجراءات التنظيمية للجهة، وبناءً على تقييم المخاطر، وبحسب المتطلبات التشريعية والتنظيمية ذات العلاقة.

الرقم	الضوابط
٢-٨-١	يجب تحديد وتوثيق واعتماد متطلبات الأمن السيبراني للتشفير في الجهة.
٢-٨-٢	يجب تطبيق متطلبات الأمن السيبراني للتشفير في الجهة.
٢-٨-٣	يجب أن تغطي متطلبات الأمن السيبراني للتشفير بحد أدنى المتطلبات المذكورة في المعايير الوطنية للتشفير الصادرة من الهيئة، مع تطبيق مستوى التشفير المناسب، وذلك بحسب طبيعة ومستوى حساسية البيانات والأنظمة والشبكات وبناءً على تقييم المخاطر من قبل الجهة وحسب المتطلبات التشريعية والتنظيمية ذات العلاقة، وفقاً لما يلي: **٢-٨-٣-١** معايير أنظمة وحلول التشفير المعتمدة والقيود المطبقة عليها (تقنياً وتنظيمياً). **٢-٨-٣-٢** الإدارة الآمنة لمفاتيح التشفير خلال عمليات دورة حياتها. **٢-٨-٣-٣** تشفير البيانات أثناء النقل والتخزين والمعالجة بناءً على تصنيفها وحسب المتطلبات التشريعية والتنظيمية ذات العلاقة.
٢-٨-٤	يجب مراجعة تطبيق متطلبات الأمن السيبراني للتشفير في الجهة دورياً.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-2-8-1	تُشفَّر البيانات أثناء النقل عبر الشبكات باستخدام TLS 1.2 أو أحدث، ويُمنع استخدام البروتوكولات غير المشفرة لنقل بيانات العملاء.
QIS-2-8-2	تُشفَّر البيانات المصنفة «مقيد» وما فوقها أثناء التخزين، وفق المعايير الوطنية للتشفير.
QIS-2-8-3	تُحفظ مفاتيح التشفير بمعزل عن البيانات التي تحميها، في خزنة مفاتيح مُدارة، وتُدوَّر سنوياً على الأقل وفور الاشتباه في انكشافها.

٤ الأمن السيبراني المتعلق بالأطراف الخارجية والحوسبة السحابية (Third-Party and Cloud Computing Cybersecurity)

تقع الشركة في موقعين من هذه الضوابط: فهي طرف خارجي لعملائها الحكوميين، وهي في الوقت نفسه جهة تتعامل مع أطراف خارجية تصل إلى بياناتها وبيانات عملائها. وتنطبق المتطلبات التالية على الموقعين.

٤-١ الأمن السيبراني المتعلق بالأطراف الخارجية (Third-Party Cybersecurity)

الهدف: ضمان حماية أصول الجهة من مخاطر الأمن السيبراني المتعلقة بالأطراف الخارجية (بما في ذلك خدمات الإسناد للأمن السيبراني أو لتقنية المعلومات "Outsourcing" والخدمات المدارة "Managed Services") وفقاً للسياسات والإجراءات التنظيمية للجهة، والمتطلبات التشريعية والتنظيمية ذات العلاقة.

الرقم	الضوابط
٤-١-١	يجب تحديد وتوثيق واعتماد متطلبات الأمن السيبراني ضمن العقود والاتفاقيات مع الأطراف الخارجية للجهة.
٤-١-٢	يجب أن تغطي متطلبات الأمن السيبراني ضمن العقود والاتفاقيات (مثل اتفاقية مستوى الخدمة SLA) مع الأطراف الخارجية التي قد تتأثر بإصابتها بيانات الجهة أو الخدمات المقدمة لها بحد أدنى ما يلي: **٤-١-٢-١** بنود المحافظة على سرية المعلومات (Non-Disclosure Clauses) والحذف الآمن من قِبَل الطرف الخارجي لبيانات الجهة عند انتهاء الخدمة. **٤-١-٢-٢** إجراءات التواصل في حال حدوث حادثة أمن سيبراني. **٤-١-٢-٣** إلزام الطرف الخارجي بتطبيق متطلبات وسياسات الأمن السيبراني للجهة والمتطلبات التشريعية والتنظيمية ذات العلاقة.
٤-١-٣	يجب أن تغطي متطلبات الأمن السيبراني مع الأطراف الخارجية التي تقدم خدمات الإسناد للأمن السيبراني أو لتقنية المعلومات، أو الخدمات المدارة بحد أدنى ما يلي: **٤-١-٣-١** إجراء تقييم لمخاطر الأمن السيبراني، والتأكد من وجود ما يضمن السيطرة على تلك المخاطر، قبل توقيع العقود والاتفاقيات أو عند تغيير المتطلبات التشريعية والتنظيمية ذات العلاقة. **٤-١-٣-٢** أن تكون مراكز عمليات خدمات الأمن السيبراني المدارة للتشغيل والمراقبة، والتي تستخدم طريقة الوصول عن بعد، موجودة بالكامل داخل المملكة.
٤-١-٤	يجب مراجعة متطلبات الأمن السيبراني مع الأطراف الخارجية دورياً.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-4-1-1	يُجرى المسح الأمني لموظفي الأطراف الخارجية والمتعاقدين قبل منحهم صلاحية الوصول إلى البيانات، ويُعاد للعاملين الحاليين بأثر رجعي.
QIS-4-1-2	يتضمن كل عقد ضمانات تعاقدية بحذف البيانات بطرق آمنة عند انتهاء العلاقة أو إنهائها، مع تقديم ما يثبت ذلك.
QIS-4-1-3	تُوثَّق جميع عمليات مشاركة البيانات مع الأطراف الخارجية في سجل مشاركة البيانات.
QIS-4-1-4	لا تُشارك البيانات خارج المملكة إلا بعد التحقق من قدرة الجهة المستضيفة على حمايتها، والحصول على موافقة صاحب الصلاحية وجهة التحكم، والالتزام بالمتطلبات النظامية.
QIS-4-1-5	يلتزم الطرف الخارجي بإبلاغ الشركة مباشرة عند حدوث أي حادثة أمن سيبراني قد تؤثر على البيانات التي شاركتها معه أو يعالجها.

QIS-4-1-6	يُعاد تصنيف البيانات إلى أقل مستوى يحقق الهدف قبل مشاركتها، باستخدام تقنيات تعتيم البيانات أو مزجها.
QIS-4-1-7	يتضمن كل عقد مع عميل بنوداً لمعالجة البيانات تحدد الغرض والنطاق ومدة الحفظ وموقع المعالجة والتزامات الإبلاغ والإعادة والإتلاف، ولا تستعين الشركة بطرف آخر لمعالجة بيانات العميل إلا بموافقته الكتابية المسبقة.

المشاريع ذات الحساسية العالية على المستوى الوطني

بند مضاف — شركة القيروان لنظم المعلومات

مستمد من متطلبات ضوابط الأمن السيبراني للبيانات للتعامل مع الأطراف الخارجية في المشاريع ذات الحساسية العالية، ويُطبَّق متى صنّف العميل المشروع بذلك.

QIS-4-1-8	يُجرى المسح الأمني لجميع موظفي الشركة والأطراف الخارجية المطلعين على بيانات المشروع، وتُوقَّع اتفاقيات عدم الإفصاح قبل البدء.
QIS-4-1-9	تُعالج بيانات المشروع على أجهزة مخصصة يوفرها العميل أو الشركة لهذا الغرض فقط، داخل قاعة مغلقة تُفعَّل فيها أنظمة التحكم بالدخول والخروج للمصرح لهم فقط.
QIS-4-1-10	يُمنع إدخال أي أجهزة إلكترونية إلى القاعة المغلقة، ويُمنع إخراج الأجهزة ووحدات التخزين والوثائق منها.

٤-٢ الأمن السيبراني المتعلق بالحوسبة السحابية والاستضافة (Cloud Computing and Hosting Cybersecurity)

الهدف: ضمان معالجة المخاطر السيبرانية وتنفيذ متطلبات الأمن السيبراني للحوسبة السحابية والاستضافة بشكل ملائم وفعّال، وذلك وفقاً للسياسات والإجراءات التنظيمية للجهة، والمتطلبات التشريعية والتنظيمية والأوامر والقرارات ذات العلاقة. وضمان حماية الأصول المعلوماتية والتقنية للجهة على خدمات الحوسبة السحابية التي تتم استضافتها أو معالجتها أو إدارتها بواسطة أطراف خارجية.

الرقم	الضوابط
٤-٢-١	يجب تحديد وتوثيق واعتماد متطلبات الأمن السيبراني الخاصة باستخدام خدمات الحوسبة السحابية والاستضافة.
٤-٢-٢	يجب تطبيق متطلبات الأمن السيبراني الخاصة بخدمات الحوسبة السحابية والاستضافة للجهة.

الرقم	الضوابط
٤-٢-٣	بما يتوافق مع المتطلبات التشريعية والتنظيمية ذات العلاقة، وبالإضافة إلى ما ينطبق من الضوابط ضمن المكونات الرئيسية رقم (١) و(٢) و(٣) والمكون الفرعي رقم (٤-١) الضرورية لحماية بيانات الجهة أو الخدمات المقدمة لها، يجب أن تغطي متطلبات الأمن السيبراني الخاصة باستخدام خدمات الحوسبة السحابية والاستضافة بحد أدنى ما يلي: **٤-٢-٣-١** حماية بيانات الجهة من قبل مقدمي خدمات الحوسبة السحابية والاستضافة بما يتوافق مع مستوى تصنيفها، وإعادتها للجهة (بصيغة قابلة للاستخدام) عند انتهاء الخدمة. **٤-٢-٣-٢** فصل البيئة الخاصة بالجهة (وخصوصاً الخوادم الافتراضية) عن غيرها من البيئات التابعة لجهات أخرى في خدمات الحوسبة السحابية.
٤-٢-٤	يجب مراجعة متطلبات الأمن السيبراني الخاصة بخدمات الحوسبة السحابية والاستضافة دورياً.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-4-2-1	تُستضاف بيانات العملاء لدى مزوّد خدمات سحابية مرخّص من هيئة الاتصالات والفضاء والتقنية، وفي مراكز بيانات داخل المملكة فقط. وهو متطلب تضعه الشركة بعد أن أحال الإصدار ٢٠٢٤ من الضوابط توطين البيانات إلى مكتب إدارة البيانات الوطنية، ويستند إلى سياسات المكتب ولائحة نقل البيانات الشخصية خارج المملكة وعقود العملاء الحكوميين.
QIS-4-2-2	تُفصل بيئة كل عميل عن بيئات العملاء الآخرين منطقياً على الأقل، وتُفصل البيئات غير الإنتاجية عن بيئات الإنتاج.
QIS-4-2-3	تُعاد بيانات العميل إليه بصيغة قابلة للاستخدام عند انتهاء العقد، ثم تُتلف من بيئات الشركة والمزوّد ويُقدَّم ما يثبت الإتلاف.

٩. المواءمة مع نظام حماية البيانات الشخصية

تعمل الشركة جهةَ معالجة لبيانات المواطنين والطلاب التي تعالجها لعملائها، فتقع مسؤولية الالتزام بالنظام أمام الهيئة السعودية للبيانات والذكاء الاصطناعي على جهة التحكم أصلاً، وتلتزم الشركة بما يمكّنها من الوفاء بذلك. ويلخص هذا القسم الالتزامات ذات الصلة بصياغة مختصرة، ويُرجع إلى نص النظام ولائحته التنفيذية عند التطبيق.

٩٫١ الغرض والحد الأدنى ومدة الحفظ

٩٫١٫١	تقتصر معالجة البيانات الشخصية على الغرض الذي جُمعت من أجله، وعلى الحد الأدنى اللازم لتحقيقه.
٩٫١٫٢	لا تُحفظ البيانات الشخصية أطول من المدة اللازمة لتحقيق الغرض، ثم تُتلف أو يُزال ما يدل على أصحابها.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.1.1	تُحدَّد مدة حفظ كل فئة من البيانات الشخصية في عقد العميل وفي سجل أنشطة المعالجة، وتُراجع البيانات المنتهية مدتها ربع سنوياً.

٩,٢ أمن البيانات الشخصية

٩,٢,١	تتخذ جهة التحكم وجهة المعالجة التدابير التنظيمية والإدارية والتقنية اللازمة لحماية البيانات الشخصية من الوصول أو الكشف أو التعديل أو الإتلاف غير المصرح به.
٩,٢,٢	تختار جهة التحكم جهة معالجة تقدم ضمانات كافية لتطبيق أحكام النظام، وتتحقق من التزامها بها.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.2.1	تُقدِّم الشركة لعملائها عند الطلب ما يثبت تطبيق ضوابط هذه السياسة، وتمكّنهم من مراجعتها وفق ما يحدده العقد.

٩,٣ الإبلاغ عن تسرب البيانات الشخصية

٩,٣,١	تُبلغ جهة التحكم الهيئةَ السعودية للبيانات والذكاء الاصطناعي عن تسرب البيانات الشخصية خلال ٧٢ ساعة من علمها به، وفق ما تحدده اللائحة التنفيذية.
٩,٣,٢	يُبلَّغ أصحاب البيانات عن التسرب متى كان من شأنه أن يلحق بهم ضرراً، وفق ما تحدده اللائحة.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.3.1	تُبلغ الشركة جهة التحكم المعنية خلال ٢٤ ساعة من اكتشاف أي تسرب يمس بياناتها، لتتمكن من الوفاء بمهلة الإبلاغ النظامية.
QIS-9.3.2	تُعامل الشركة كل تسرب للبيانات الشخصية حادثةً واجبة الإبلاغ إلى جهة التحكم، دون انتظار تقدير الضرر، أخذاً بالقاعدة الأشد في مسودة تعديلات اللائحة المطروحة لاستطلاع الآراء.

٩,٤ نقل البيانات الشخصية خارج المملكة

٩,٤,١	لا يجوز نقل البيانات الشخصية خارج المملكة أو الإفصاح عنها لجهة خارجها إلا في الحالات وبالضوابط التي يحددها النظام ولائحة نقل البيانات الشخصية خارج المملكة.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.4.1	لا تنقل الشركة بيانات العملاء الشخصية خارج المملكة في أي حال، إلا بطلب كتابي من جهة التحكم تتحمل فيه مسؤولية استيفاء الضوابط النظامية.

٩٫٥ حقوق أصحاب البيانات

٩٫٥٫١	لأصحاب البيانات حقوق يكفلها النظام، منها العلم بالمعالجة، والوصول إلى بياناتهم، وطلب تصحيحها أو إتلافها.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.5.1	تُحال طلبات أصحاب البيانات التي تصل إلى الشركة إلى جهة التحكم خلال يومي عمل، وتساعدها الشركة على تلبيتها في المدد النظامية.

٩٫٦ تقييم الأثر

٩٫٦٫١	يُجرى تقييم لأثر معالجة البيانات الشخصية في الحالات التي تحددها اللائحة، ومنها المعالجة التي قد تنطوي على مخاطر عالية على أصحاب البيانات.

متطلبات تنفيذية إضافية — شركة القيروان لنظم المعلومات

QIS-9.6.1	يُجرى تقييم لأثر حماية البيانات بالتنسيق مع جهة التحكم قبل أي تغيير جوهري في بوابة المواطنين أو أي نظام يعالج بيانات شخصية.

١٠. مؤشرات الأداء الرئيسية (KPIs) لحماية البيانات

الرمز	المؤشر	الهدف	التكرار
KPI-01	نسبة الأنظمة المستضافة التي حُدِّد تصنيف بياناتها ومالكها ووُثِّق	١٠٠٪	ربع سنوي
KPI-02	نسبة العقود (الجديدة والسارية) التي راجعتها الحوكمة والمخاطر والالتزام وتتضمن متطلبات الأمن السيبراني وبنود الحذف الآمن	١٠٠٪	شهري
KPI-03	نسبة الأشخاص الذين يصلون إلى بيانات العملاء ولديهم اتفاقية سرية سارية	١٠٠٪	شهري
KPI-04	نسبة موظفي الأطراف الخارجية والمتعاقدين الذين أكملوا المسح الأمني قبل منحهم الوصول	١٠٠٪	شهري
KPI-05	نسبة عمليات مشاركة البيانات الموثقة كاملة والمُعاد تصنيفها قبل المشاركة	١٠٠٪	شهري
KPI-06	نسبة قواعد البيانات المستضافة المشفرة أثناء التخزين	١٠٠٪	ربع سنوي
KPI-07	نسبة العلاقات المنتهية التي قُدِّم فيها دليل الإعادة أو الإتلاف الآمن	١٠٠٪	ربع سنوي

الرمز	المؤشر	الهدف	التكرار
KPI-08	نسبة طلبات أصحاب البيانات المحالة إلى جهة التحكم خلال يومي عمل	١٠٠٪	شهري
KPI-09	نسبة الموظفين والمتعاقدين الذين أكملوا تدريب حماية البيانات السنوي	٩٥٪	ربع سنوي

١١. مؤشرات أداء المخاطر (KRIs) لحماية البيانات

مفتاح الألوان (RAG Status)

اللون	الحالة	المعنى والإجراء المطلوب
أخضر	**ضمن الهدف / مقبول**	المؤشر ضمن العتبة المقبولة، ويُستمر في المتابعة الروتينية.
أصفر	**يحتاج إلى انتباه**	تجاوز المؤشر الحد المقبول، ويتطلب متابعة فورية وتصحيحًا خلال الفترة المحددة.
أحمر	**خطر / عدم امتثال**	تجاوز المؤشر العتبة الحرجة، ويتطلب تصعيدًا فوريًا للإدارة العليا وخطة معالجة عاجلة.

الرمز	المؤشر	العتبة	التكرار
KRI-01	عدد الأنظمة التي تحتفظ ببيانات «مقيد» أو أعلى دون تصنيف موثق	أخضر: ٠ · أصفر: ١ · أحمر: ٢ فأكثر	ربع سنوي
KRI-02	عدد العقود التي تتعامل مع بيانات الشركة أو عملائها دون متطلبات الأمن السيبراني المعتمدة	أخضر: ٠ · أصفر: ١ · أحمر: ٢ فأكثر	شهري
KRI-03	عدد الأطراف الخارجية أو موظفيهم الذين يصلون إلى البيانات دون مسح أمني أو اتفاقية سرية سارية	أخضر: ٠ · أصفر: ١ · أحمر: ٢ فأكثر	شهري
KRI-04	حالات مشاركة بيانات دون توثيق أو دون إعادة تصنيف	أحمر: أي حالة	شهري
KRI-05	حوادث تسرب أُبلغت بها جهة التحكم بعد أكثر من ٢٤ ساعة من اكتشافها	أحمر: أي حالة	عند كل حادثة
KRI-06	مواقع تخزين أو معالجة لبيانات العملاء خارج المملكة	أحمر: أي حالة	ربع سنوي
KRI-07	بيئات غير إنتاجية تحتوي بيانات شخصية غير مُعتَّمة	أحمر: أي حالة	ربع سنوي
KRI-08	مخالفات القاعة المغلقة في المشاريع ذات الحساسية العالية	أحمر: أي حالة	أسبوعي

١٢. عواقب عدم الامتثال

في حال عدم الالتزام بهذه السياسة قد يتعرض الموظف أو المتعاقد لإجراءات تأديبية وفق اللوائح الداخلية، تشمل الإنذار الرسمي، أو تقييد الصلاحيات أو سحبها، أو الإيقاف، أو إنهاء العقد، بحسب جسامة المخالفة وأثرها. وتُعامل مخالفات الأطراف الخارجية وفق شروط العقد، وقد تؤدي إلى إنهائه، دون الإخلال بالمسؤولية النظامية.

١٣. آلية التواصل

نوع الطلب / البلاغ	الجهة المسؤولة	آلية التواصل
الاستفسارات عن السياسة	مسؤول حماية البيانات الشخصية	privacy@qis.example
مراجعة متطلبات الأمن السيبراني في عقد	قائد الحوكمة والمخاطر والالتزام	وفق الإجراء الأول في QIS-PRC-001
طلب مشاركة بيانات مع طرف خارجي	مالك البيانات	وفق الإجراء الثاني في QIS-PRC-001
الإبلاغ عن تسرب فعلي أو مشتبه به	العمليات والهندسة الأمنية	security@qis.example — التحويلة ٢١٠٠
طلب من صاحب بيانات	مسؤول حماية البيانات الشخصية	privacy@qis.example

١٤. المراجعة وتحديث السياسة

١٤٫١ مراجعة السياسة

يتولى قائد الحوكمة والمخاطر والالتزام مراجعة هذه السياسة سنوياً على الأقل، للتحقق من ملاءمتها وفعاليتها، ويرفع نتائج المراجعة إلى اللجنة الإشرافية للأمن السيبراني.

١٤٫٢ تحديث السياسة

تُحدَّث هذه السياسة عند تغيّر الأنظمة واللوائح ذات العلاقة، ومنها صدور تعديلات اللائحة التنفيذية لنظام حماية البيانات الشخصية بصيغتها النهائية، أو عند تغيّر خدمات الشركة أو عملائها، أو بعد حادثة جوهرية تمس البيانات.

١٥. المراجع

النوع	رمز المرجع	اسم المرجع	الجهة
خارجي	ECC-2:2024	الضوابط الأساسية للأمن السيبراني — بُني عليها القسم ٨	الهيئة الوطنية للأمن السيبراني
خارجي	DCC-1:2022	ضوابط الأمن السيبراني للبيانات	الهيئة الوطنية للأمن السيبراني
خارجي	PDPL	نظام حماية البيانات الشخصية ولائحته التنفيذية — بُني عليها القسم ٩	الهيئة السعودية للبيانات والذكاء الاصطناعي
خارجي	—	لائحة نقل البيانات الشخصية خارج المملكة	الهيئة السعودية للبيانات والذكاء الاصطناعي
خارجي	—	السياسات والمعايير الوطنية لإدارة البيانات (توطين البيانات وحمايتها)	مكتب إدارة البيانات الوطنية
داخلي	QIS-PRC-001	إجراءات حماية البيانات	QIS
داخلي	QIS-PRF-001	ملف الشركة ونطاق البرنامج	QIS
داخلي	QIS-RR-001	سجل المخاطر (R-01، R-05، R-14)	QIS
داخلي	QIS-IRP-001	خطة الاستجابة للحوادث السيبرانية	QIS
داخلي	QIS-POL-002	سياسة استخدام الذكاء الاصطناعي	QIS

نُقلت أهداف الضوابط ونصوصها في القسم ٨ حرفياً من النص العربي الرسمي للضوابط الأساسية للأمن السيبراني (ECC-2:2024) في ١١ نوفمبر ٢٠٢٦م. وتبقى ملخصات النظام في القسم ٩ بحاجة إلى مطابقة مع النصوص الرسمية قبل اعتماد الإصدار ١,٠.